

RAPPORT D'ANALYSE GRC

Vul scan.pdf

12%

Score de Maturité Global

Statistiques	Risques	Conformités	Recommandations
Total identifiés	18	37	15

Généré le 30/05/2026 à 12:43
Document confidentiel — Usage interne uniquement

1. Résumé Exécutif

1. CONTEXTE ET OBJET DU DOCUMENT Ce document analyse le rapport de scan de vulnérabilités produit le 21 mai 2025 par Evolvity Partners avec Giantlink dans le cadre d'un abonnement "Cyber Companion". Il s'agit d'un scan automatisé trimestriel ciblant les actifs web de l'organisation, avec une méthodologie alignée sur les bonnes pratiques industrielles.

2. PRINCIPALES CONCLUSIONS - 18 risques identifiés au total, tous de sévérité moyenne ou faible. - Aucun risque critique ou élevé détecté, mais 8 risques classés comme moyens. - Score de conformité global faible : ISO 27001 à 15 %, RGPD et Loi 09-08 à 10 %. - Maturité globale évaluée à 11,7 %, indiquant un niveau de sécurité immature. - Les vulnérabilités liées aux politiques de sécurité du contenu (CSP) dominent les risques moyens. - Les recommandations de remédiation sont en cours de traitement pour l'ensemble des risques.

3. RISQUES PRIORITAIRES - Absence de tokens Anti-CSRF (sévérité : MOYEN, score : 9,0) : expose l'application à des attaques par falsification de requêtes intersites, compromettant l'intégrité des transactions utilisateur. - CSP : absence de directive avec mécanisme de repli (sévérité : MOYEN, score : 9,0) : affaiblit la protection contre les attaques XSS et l'exécution de scripts malveillants. - CSP : utilisation de directives wildcard (sévérité : MOYEN, score : 9,0) : réduit l'efficacité du CSP en autorisant des sources non contrôlées, augmentant le risque d'injection de contenu. - CSP : script-src unsafe-inline (sévérité : MOYEN, score : 9,0) : contourne les restrictions CSP et facilite l'exécution de scripts non autorisés. - CSP : style-src unsafe-inline (sévérité : MOYEN, score : 9,0) : permet l'injection de styles malveillants, affectant l'apparence et le comportement de l'application.

4. ETAT DE CONFORMITE ISO 27001 : 15 % | RGPD : 10 % | Loi 09-08 : 10 % La posture de conformité est préoccupante, avec des écarts significatifs par rapport aux exigences réglementaires et normatives, notamment en matière de protection des données et de gestion des risques.

5. ACTIONS IMMEDIATES RECOMMANDEES 1. Déployer des tokens Anti-CSRF sur l'ensemble des formulaires et requêtes sensibles pour éliminer le risque de falsification de requêtes. 2. Revoir et renforcer la politique CSP en supprimant les directives unsafe-inline et wildcard, et en définissant des sources explicites avec des mécanismes de repli. 3. Corriger les en-têtes de sécurité manquants (Anti-clickjacking, X-Content-Type-Options, Strict-Transport-Security) pour réduire les risques d'exploitation des vulnérabilités web courantes.

6. CONCLUSION L'analyse révèle une exposition modérée mais généralisée à des risques de sécurité web, avec une conformité réglementaire et normative très en deçà des attentes. Bien qu'aucun risque critique ne soit identifié, la concentration de vulnérabilités moyennes liées aux politiques CSP et à la gestion des requêtes expose l'organisation à des attaques exploitables. Une remédiation prioritaire des risques identifiés, couplée à un plan d'amélioration de la maturité globale, est nécessaire pour réduire l'exposition et aligner la posture de sécurité sur les exigences légales et industrielles. L'urgence est modérée, mais une action rapide est recommandée pour éviter une dégradation du niveau de risque.

2. Analyse des Risques

Sévérité	Nombre	% du total
CRITIQUE	0	0%
ELEVE	0	0%
MOYEN	8	44%
FAIBLE	10	56%

Détail des risques identifiés

#	ID	Libellé & Description	Cat.	P	I	Sco re	Sévérité
1	M1	Absence of Anti-CSRF Tokens No Anti-CSRF tokens were found in HTML submission forms across 3 instances. This vulnerability (CWE-352) allows attackers to force victims to send unintended HT...	CYBER	3	3	9	MOYEN
2	M2	CSP: Failure to Define Directive with No Fallback The Content Security Policy (CSP) fails to define critical directives (frame-ancestors, form-action) without fallback, effectively allowing any source for these...	CYBER	3	3	9	MOYEN
3	M3	CSP: Wildcard Directive The Content Security Policy (CSP) uses wildcard directives (e.g., 'script-src *'), which allows scripts to be loaded from any origin. This misconfiguration (CWE...	CYBER	3	3	9	MOYEN
4	M4	CSP: script-src unsafe-inline The Content Security Policy (CSP) includes the 'unsafe-inline' directive for 'script-src', allowing inline scripts to execute. This misconfiguration (CWE-693) b...	CYBER	3	3	9	MOYEN
5	M5	CSP: style-src unsafe-inline The Content Security Policy (CSP) includes the 'unsafe-inline' directive for 'style-src', allowing inline styles to be applied. This misconfiguration (CWE-693)...	CYBER	3	3	9	MOYEN
6	M6	Missing Anti-clickjacking Header The X-Frame-Options header is missing, exposing the application to clickjacking attacks (CWE-1021). Attackers can embed the site in an iframe and trick users in...	CYBER	3	3	9	MOYEN
7	M7	Sub Resource Integrity Attribute Missing External resources (e.g., stylesheets from Google Fonts) are loaded without Subresource Integrity (SRI) attributes, exposing the application to risks like CDN c...	CYBER	3	3	9	MOYEN
8	M8	Vulnerable JS Library The application uses outdated and vulnerable JavaScript libraries: Bootstrap v3.3.6 and jQuery v1.11.1. These versions are affected by multiple CVEs, including...	CYBER	3	3	9	MOYEN
9	L1	Insufficient Site Isolation Against Spectre Vulnerability The Cross-Origin-Resource-Policy (CORP) header is not set, leaving the application vulnerable to Spectre-based side-channel attacks (CWE-693). Attackers could e...	CYBER	2	2	4	FAIBLE
10	L2	Permissions Policy Header Not Set The Permissions Policy header is missing, allowing unauthorized access to browser features (e.g., camera, microphone, geolocation) by web resources (CWE-693). T...	CYBER	2	2	4	FAIBLE

1 1	L3	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) The server leaks PHP version information (8.2.28) via the 'X-Powered-By' header, aiding attackers in identifying potential vulnerabilities (CWE-497). This infor...	CYBER	2	2	4	FAIBLE
1 2	L4	Strict-Transport-Security Header Not Set The HTTP Strict Transport Security (HSTS) header is missing, exposing the application to downgrade attacks (e.g., SSL stripping) and session hijacking (CWE-523)...	CYBER	2	2	4	FAIBLE
1 3	L5	X-Content-Type-Options Header Missing The X-Content-Type-Options header is missing, allowing browsers to perform MIME sniffing and interpret files as unintended types (CWE-693). This increases the r...	CYBER	2	2	4	FAIBLE
1 4	I1	Information Disclosure - Suspicious Comments The application contains suspicious comments in JavaScript files, including sensitive keywords like 'TODO', 'FIXME', 'FROM', and 'PASSWORD' (CWE-615). These com...	CYBER	1	2	2	FAIBLE
1 5	I2	Modern Web Application The application uses modern web features (e.g., data-toggle attributes) without traditional href links, indicating it may rely on JavaScript frameworks. While n...	CYBER	1	2	2	FAIBLE
1 6	I3	Re-examine Cache-control Directives The Cache-Control header is missing or improperly configured, allowing browsers and proxies to cache content (CWE-525). This could lead to sensitive data exposu...	CYBER	1	2	2	FAIBLE
1 7	I4	Retrieved from Cache The application's responses are being served from a shared cache (e.g., proxy servers), as indicated by the 'Age' header. This could lead to sensitive data expo...	CYBER	1	2	2	FAIBLE
1 8	I5	Storable and Cacheable Content The application's responses are cacheable for extended periods (e.g., 1 year heuristic or max-age=604800), increasing the risk of sensitive data exposure via sh...	CYBER	1	2	2	FAIBLE

3. Résultats de Conformité

ISO 27001 — Taux moyen: 15%

Domaine	Statut	Taux	Écart
A.5 Information Security Policies	NON_CONFORME	0%	No explicit or implicit evidence of information security policies, their review,
A.6 Organisation of Information Security	NON_CONFORME	0%	No mention of roles, responsibilities, or segregation of duties related to infor
A.7 Human Resource Security	NON_CONFORME	0%	No evidence of screening, training, or termination procedures. The document type
A.8 Asset Management	PARTIEL	20%	The scan targets specific assets (e.g., URLs, IPs), implying some level of asset
A.9 Access Control	PARTIEL	30%	The scan identifies access control issues (e.g., missing Anti-CSRF tokens, auth
A.10 Cryptography	PARTIEL	25%	The scan identifies missing security headers (e.g., Strict-Transport-Security) a
A.11 Physical and Environmental Security	NON_CONFORME	0%	No evidence of physical access controls or equipment protection. The document ty
A.12 Operational Security	PARTIEL	50%	The scan addresses vulnerability management, logging, and monitoring (e.g., pass
A.13 Communications Security	PARTIEL	40%	The scan identifies multiple communication security issues (e.g., missing HTTP s
A.14 System Acquisition, Development and Maintenance	PARTIEL	30%	The scan identifies vulnerable JavaScript libraries and insecure coding practice
A.15 Supplier Relationships	NON_CONFORME	0%	No evidence of supplier contracts, third-party risk management, or supplier secu
A.16 Information Security Incident Management	NON_CONFORME	0%	No evidence of incident response procedures, breach handling, or incident report
A.17 Business Continuity Management	NON_CONFORME	0%	No evidence of BCP, DRP, or recovery objectives. The document type does not addr
A.18 Compliance	PARTIEL	20%	The scan references industry best practices (e.g., OWASP, CVSS) and identifies c

RGPD — Taux moyen: 6%

Domaine	Statut	Taux	Écart
Licéité du traitement (Art.6) — lawful basis for each proces	NON_CONFORME	0%	The document is a vulnerability scanning report and does not address or imply an
Droits des personnes concernées (Art.12-23) — access, rectif	NON_CONFORME	0%	The document does not mention or imply any mechanisms for data subjects to exerc
Consentement (Art.7-8) — freely given, specific, informed, u	NON_CONFORME	0%	The document does not discuss or imply any processes related to obtaining, recor

Protection des données dès la conception (Art.25) — privacy	PARTIEL	30%	The document implicitly addresses privacy by design through findings related to
Responsabilités du responsable de traitement (Art.24-26) — D	NON_CONFORME	0%	The document does not mention or imply any responsibilities of the data controll
Registre des activités de traitement (Art.30) — records of p	NON_CONFORME	0%	The document does not reference or imply the existence of a record of processing
Sécurité du traitement (Art.32) — technical and organisation	PARTIEL	40%	The document explicitly identifies technical security vulnerabilities (e.g., mis
Notification des violations de données (Art.33-34) — 72h bre	NON_CONFORME	0%	The document does not mention or imply any processes for detecting, reporting, o
Analyse d'impact (AIPD/DPIA) (Art.35) — risk assessment for	NON_CONFORME	0%	The document does not reference or imply the conduct of a Data Protection Impact
Délégué à la protection des données (DPO) (Art.37-39) — DPO	NON_CONFORME	0%	The document does not mention or imply the designation or role of a Data Protect
Transferts de données hors UE (Art.44-49) — adequacy decisio	NON_CONFORME	0%	The document does not address or imply any data transfers outside the EU or mech
Information des personnes (Art.13-14) — privacy notices, tra	NON_CONFORME	0%	The document does not mention or imply the provision of privacy notices or trans

Loi 09-08 — Taux moyen: 4%

Domaine	Statut	Taux	Écart
Droit à l'information (Art.4-6) — informing data subjects be	NON_CONFORME	0%	The document is a vulnerability scanning report and does not address or mention
Consentement (Art.4) — prior, free, specific, and informed c	NON_CONFORME	0%	The document does not reference consent mechanisms, data collection practices, o
Droits des personnes concernées (Art.7-11) — access, rectifi	NON_CONFORME	0%	There is no mention of data subject rights (access, rectification, opposition, o
Sécurité des données personnelles (Art.23) — technical and o	PARTIEL	40%	The document identifies multiple security vulnerabilities (e.g., missing Anti-CS
Notification des violations de données (Art.23) — breach not	NON_CONFORME	0%	The document does not mention breach notification procedures, incident response
Délégué à la protection des données (Art.24) — DPO or respon	NON_CONFORME	0%	There is no reference to a Data Protection Officer (DPO) or a designated respons
Analyse d'impact relative à la vie privée (PIA) — privacy im	NON_CONFORME	0%	The document does not mention any privacy impact assessments (PIAs) or risk asse
Registre des traitements (Art.17-22) — declaration/authorisa	NON_CONFORME	0%	There is no mention of a register of processing activities or compliance with Ar

Transfert international de données (Art.43-44) — restriction	NON_CONFORME	0%	The document does not address cross-border data transfers or compliance with Art
Sensibilisation et formation — staff awareness and training	NON_CONFORME	0%	The document does not reference staff training, awareness programs, or data prot
Gestion des sous-traitants (Art.13) — processor agreements a	NON_CONFORME	0%	There is no mention of processor agreements, subcontractor management, or compli

4. Recommendations

#	Recommandation	Priorité	Type	Effort	Statut
1	Implement Anti-CSRF Tokens Across All HTML Forms	MOYENNE	Rapide	MOYEN	À faire
2	Enforce CSP Directives with Explicit Fallbacks for Critical Sources	MOYENNE	Long terme	MOYEN	À faire
3	Replace CSP Wildcard Directives with Explicit Allowlists	MOYENNE	Long terme	MOYEN	À faire
4	Remove 'unsafe-inline' from CSP script-src Directive	MOYENNE	Long terme	MOYEN	À faire
5	Remove 'unsafe-inline' from CSP style-src Directive	MOYENNE	Long terme	MOYEN	À faire
6	Add X-Frame-Options Header to Prevent Clickjacking	MOYENNE	Rapide	FAIBLE	À faire
7	Add Subresource Integrity (SRI) Attributes to External Resources	MOYENNE	Rapide	FAIBLE	À faire
8	Upgrade Vulnerable JavaScript Libraries to Patched Versions	MOYENNE	Rapide	FAIBLE	À faire
9	Set Cross-Origin-Resource-Policy Header to 'same-origin'	FAIBLE	Rapide	FAIBLE	À faire
10	Add Permissions Policy Header to Restrict Browser Features	FAIBLE	Rapide	FAIBLE	À faire
11	Remove X-Powered-By Header to Prevent Information Disclosure	FAIBLE	Rapide	FAIBLE	À faire
12	Enable HTTP Strict Transport Security (HSTS)	FAIBLE	Rapide	FAIBLE	À faire
13	Add X-Content-Type-Options Header to Prevent MIME Sniffing	FAIBLE	Rapide	FAIBLE	À faire
14	Remove Sensitive Comments from JavaScript Files	FAIBLE	Rapide	MOYEN	À faire
15	Configure Cache-Control Headers for Sensitive Responses	FAIBLE	Rapide	FAIBLE	À faire